

TechGlobal Governance Transformation Simulation

Comprehensive Lab Report & Supporting Governance Artefacts
Course: GRC102 – Information Security Governance | Module 3

Submission Date: September 25, 2026 | Scope: 2,500 Employees Across 5 Global Offices

Task 1: Governance Architecture and Stakeholder Map

1. Governance Gap Assessment (Weaknesses & Consequences)

TechGlobal currently operates on a model of 'security by informal decision,' which creates severe organizational vulnerabilities across its five global offices. The key structural weaknesses and their business consequences include:

- **Concentration of Authority with the IT Director:** The IT Director acts simultaneously as security owner, risk approver, and operational decision-maker. Consequence: Creates a single point of failure, severe operational bottlenecks, and a conflict of interest where delivery speed outweighs security rigor.
- **Absence of a Formal Governance Committee Structure:** There are no cross-functional forums to review risk, investment, or compliance collectively. Consequence: Security decisions are made in isolated silos without input from legal, finance, or business units.
- **Inconsistent Business Unit Operations:** Business units make local security choices independently without unified oversight. Consequence: Amplifies operational risk, creates uneven security postures across the five global offices, and exposes systemic vulnerabilities.
- **Limited Board and CEO Visibility:** Executive leadership and the Board receive minimal visibility into cyber risk. Consequence: Prevents informed governance oversight, increases regulatory exposure, and leaves the organization unprepared for material incidents.
- **Reliance on Informal Escalation Paths:** There are no reliable paths for escalating risks or incidents. Consequence: Critical risks linger at operational levels until they manifest as major breaches or compliance failures.

2. Stakeholder Map

A structured analysis of TechGlobal's key governance stakeholders, detailing their authority, primary interests, information needs, and governance contributions:

Stakeholder	Authority / Influence	Primary Interest	Governance Contribution
Board of Directors	Oversight and risk appetite	Regulatory exposure, brand reputation, material risk, assurance	Ultimate accountability and strategic risk governance
CEO	Executive accountability	Growth, strategic alignment, acceptable risk, business performance	Aligns security strategy with corporate growth objectives
CISO	Security governance leadership	Security strategy, policy, risk oversight, programme effectiveness	Directs operational security and risk management programs
CRO / Risk	Enterprise risk integration	Risk methodology, risk acceptance, treatment, aggregation	Integrates cyber risk into enterprise risk management frameworks
Legal / Compliance	Legal and regulatory advice	Regulatory duties, contractual obligations, privacy, notification	Ensures compliance with statutory obligations and privacy laws
Finance	Financial governance	Budget, loss exposure, investment prioritisation, financial controls	Allocates security budgets and oversees financial controls
Human Resources	People governance	Joiner/mover/leaver controls, awareness, conduct, discipline	Manages workforce security awareness and insider threat controls
IT / Technology	Technology delivery	Secure operation, implementation, technical control ownership	Implements technical controls and maintains service continuity
Business Units	Business ownership	Operational performance, local risk decisions, implementation	Enforces security standards across operational workflows

3. Security Governance Organisation Chart & Consultant Justification

The proposed governance structure establishes clear reporting lines connecting operational security teams upward to the Executive Security Council, cross-functional Steering Committees, and ultimately to the CEO and Board of Directors.

Consultant Justification: A formal, scalable structure is essential because informal governance breaks down rapidly beyond small team sizes. With 2,500 employees distributed across five offices, centralized IT oversight cannot adequately manage local business unit risks or address regional regulatory nuances without clear reporting lines, defined oversight relationships, and structured communication paths.

Task 2: Governance Responsibility and Authority Matrix

1. Core Role Profiles Summary

Defining explicit decision rights and accountabilities across TechGlobal's eight core governance roles:

Role	Purpose	Core Responsibilities	Decision Authority	Reports To	KPIs
Board of Directors	Ultimate oversight and strategic risk governance	Reviews material cyber risks and defines organizational risk appetite	Approves risk appetite, cyber strategy, and material disclosures	Shareholders / Regulators	Board reporting compliance, material risk governance efficacy
CEO	Overall enterprise leadership and strategic alignment	Directs business performance and aligns security with corporate growth	Executive resource allocation and major dispute resolution	Board of Directors	Alignment of security strategy with growth objectives
CISO	Directs security programme and operationalizes governance	Manages security strategy, policy compliance, and risk oversight	Policy drafting, security architecture approval, tactical risk management	CEO & Executive Security Council	Vulnerability remediation time, security incident frequency
CRO / Risk	Integrates cyber risk into enterprise-wide risk management	Oversees risk methodology, aggregation, and treatment tracking	Validates risk methodologies and oversees risk registers	CEO & Board Risk Committee	Enterprise risk aggregation accuracy, coverage of assessments

Legal / Compliance	Ensures regulatory alignment and contractual adherence	Advises on regulatory duties, privacy, and contractual obligations	Determines regulatory notification and privacy compliance duties	CEO and Board	Compliance audit findings, timely regulatory filings
Finance	Manages financial controls and budget allocation	Oversees security budgeting, loss exposure, and prioritization	Approves security investments and capital expenditures	CEO and Board Audit Committee	Budget variance, ROI on security tools
HR	Manages human capital security and workforce conduct	Controls joiner/mover/leaver processes and security awareness	Enforces security awareness policies and disciplinary protocols	CEO	Employee awareness completion rates, insider threat counts
IT / Technology	Delivers secure technology infrastructure and operations	Maintains technical control ownership, secure operations, continuity	Implements technical controls and manages service continuity	CEO / CISO	System uptime, patch deployment velocity

2. Conflict-Resolution Note

Overlapping Authorities: Potential conflicts exist between IT (speed and service delivery) and CISO/Security (control enforceability), as well as between Finance (cost minimization) and CRO/CISO (risk mitigation investment) .

Resolution Principles: Establish the Security Governance Committee as the primary escalation forum where cross-functional trade-offs are evaluated against enterprise risk appetite. Final decision rights default to the CEO or Board when deadlock impacts material organizational risk .

Task 3: Security Governance Committee Ecosystem

1. Committee Structure & Information Flow

TechGlobal's governance committee ecosystem is designed to eliminate silos and drive collaborative decision-making :

- **Executive Security Council:** Focuses on strategic oversight, alignment with business goals, and enterprise-wide resource prioritization .

- **Security Governance / Steering Committee:** A cross-functional forum handling operational governance decisions, policy reviews, and inter-departmental conflict resolution .
- **Specialised Working Group (e.g., Incident Response / Third-Party Risk):** Focuses on technical or domain-specific deep dives, such as evaluating third-party vendor risks across global offices .
- **Business Unit Participation:** Business units participate through designated security liaisons within working groups and steering committees, ensuring operational needs are met without creating fragmented security silos .
- **Information Flow:** Risk information and decisions flow bottom-up from operational teams to steering committees, escalate to executive management when thresholds are breached, and reach the Board for material risks .

2. Governance Artefacts & Decision Log

Sample Committee Decision Log (Appendix D Format):

Date	Decision / Issue	Owner	Decision	Rationale	Actions / Owner	Review Date
2026-10-01	Cloud Access Security Broker (CASB) rollout delay	CISO	Approve phased deployment over 3 months	Minimizes business disruption across global offices	IT Lead to stage rollout	2026-11-01
2026-10-15	Third-party vendor risk threshold	CRO	Mandate SOC 2 Type II for all tier-1 vendors	Addresses rising supply chain risk exposures	Procurement Lead	2026-12-01
2026-11-02	Remote access MFA exception request	IT Director	Reject exception for legacy billing system	Risk level exceeds acceptable organizational tolerance	IT Security Team	2026-12-02

Task 4: RACI Accountability Matrix

1. Completed TechGlobal RACI Matrix (Appendix C)

Legend: A = Accountable, R = Responsible, C = Consulted, I = Informed

Activity	Board	CEO	CISO	CRO	Legal	Finance	HR	IT	BU
----------	-------	-----	------	-----	-------	---------	----	----	----

Cybersecurity strategy approval	A	C	R	C	I	C	I	C	C
Security policy approval	I	I	A	C	C	I	I	R	C
Enterprise cyber-risk assessment	I	C	R	A	I	I	I	C	C
Risk acceptance	I	A	C	C	I	I	I	I	R
Security budget approval	I	A	R	I	I	C	I	C	I
Security architecture approval	I	I	A	I	I	I	I	R	I
Third-party security review	I	I	R	C	C	I	I	C	A
Access governance	I	I	C	I	I	I	R	A	C
Incident response governance	I	I	A	C	C	I	I	R	C
Material incident escalation	I	A	R	C	C	I	I	I	I
Regulatory notification decision	I	C	C	C	A	I	I	I	I
Security awareness	I	I	R	I	I	I	A	I	C

programm e									
Vulnerabili ty remediatio n oversight	I	I	C	I	I	I	I	A	R
Business continuity / recovery governanc e	I	C	C	C	I	I	I	R	A
Board cyber-risk reporting	I	C	R	C	I	I	I	I	I

2. Implementation Guide

Managers must use the RACI matrix during project planning, technology deployments, and incident management to eliminate ambiguity, guarantee that every activity has exactly one clear Accountable role, and ensure proper consultation with Legal, Finance, and Risk .

Task 5: Cyber-Risk Escalation and Segregation of Duties

1. Cyber-Risk Escalation Threshold Table (Appendix E)

Level	Example Trigger	Decision Authority	Required Notification	Target Response
Level 1 – Operational	Localized vulnerabilities or minor incidents	IT / Security Operations Lead	CISO & IT Director	Within 24 hours
Level 2 – Executive	Significant cross-office risks or recurring non-compliance	Security Governance Committee / CISO	CEO, CRO, Affected Business Units	Within 4 hours
Level 3 – Board / Material	Major security breaches, severe regulatory penalties, existential threats	CEO and Board of Directors	Board, Legal Counsel, Regulators	Immediate / < 1 hour

2. Segregation-of-Duties (SoD) Weakness Register (Appendix F)

ID	Weakness / Conflict	Risk Created	Roles Involved	Recommended Control	Residual Risk / Review
1	IT Director acts as sole risk approver and system implementer	Conflict of interest and unchecked operational risk	IT and Security	Separate technical deployment from risk acceptance via CRO/CISO	Low / Annual review
2	Unchecked local security configurations by business units	Inconsistent security posture across global offices	Business Units & IT	Implement mandatory centralized security baselines	Low / Quarterly review
3	Lack of independent audit for access provisioning	Potential insider threat or privilege abuse	HR and IT	Institute dual-control sign-offs between HR and IT	Low / Biannual review
4	Informal third-party onboarding	Unvetted vendor security vectors	Procurement, Legal, IT	Require formal vendor risk assessments coordinated centrally	Medium / Annual review
5	Undocumented risk acceptance	Loss of institutional accountability and regulatory liability	Management & Executive	Enforce a formal decision log and register for all accepted risks	Low / Continuous

3. Decision-Recording & Assurance Note

All significant governance decisions, risk exceptions, and escalations must be logged centrally with a complete audit trail (tracking rationale, approver, and review date) to ensure ongoing accountability and regulatory defensibility .